

SITE SECURITY

AUDIT PROGRAM #48-20-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
November 2023	Planning-Reference material	IBM Security Manual	Alejandro Balekian	Update: link to current SECMAN link (including recent updates to process)
April 2023	Data Privacy & IT Security	DP001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

SITE SECURITY

AUDIT PROGRAM #48-20-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	7
PLANNING: Fraud Template.....	8
CONTROL ASSESSMENT QUESTIONS	9
Key Control Question: 1. Contract Management.....	9
Primary Test: Contract Management (CM001.P).....	10
Secondary Test: Contract Management-Information Access (CM002.S)	11
Key Control Question: 2. Risk Analysis.....	12
Primary Test: Risk Analysis (RA001.P).....	13
Key Control Question: 3. Physical Security - Exterior and Interior Security	14
Primary Test: Exterior Access Controls (PS001.P)	15
Primary Test: Interior Access Controls (PS002.P).....	16
Primary Test: Search Policy (PS007.P).....	19
Key Control Question: 4. Physical Security - Master Keys and CAS	20
Primary Test: Lock and Key Controls (PS004.P)	21
Primary Test: Access Controls and Badge Designs (PS005.P)	22
Secondary Test: Badge Designs and Technology (PS006.S)	24
Key Control Question: 5. Emergency Planning	25
Primary Test: Emergency Planning (EP001.P)	26
Key Control Question: 6. Incident Management	27
Primary Test: Reporting Incidents (IM001.P).....	28
Secondary Test: Investigations (IM002.S).....	29
Key Control Question: 7. Data Privacy and IT Security	30
Primary Test: Data Privacy and IT Security (DP001.P)	31
Key Control Question: 8. Employee Transportation Services	33
Primary Test: Employee Transportation Services (TS001.P).....	34
Key Control Question: 9. Education	35
Primary Test: Education (ED001.P)	36

SITE SECURITY

AUDIT PROGRAM #48-20-00

PROCESS AND OBJECTIVE

IBM's security program has four components: Risk analysis, physical security, emergency planning and crisis management support, and incident management. Each IBM location should have procedures that provide:

- A secure working environment for IBM employees and other persons working at, or visiting, IBM facilities.
- The protection of IBM's intellectual and physical assets.
- The protection of IBM's facilities.
- Local specifics and risks have been identified by management and have been adequately addressed and controls are evident.

Note: The IBM Security Manual does not cover physical security for the following: Locations designated as a conference center, Physical security of parts locations are covered by the requirements of 'Corporate Logistics Procedure 10.13.' / Physical security of IT space is covered by 'IT Security Standard' / Physical security of International Traffic in Arms Regulations (ITAR) space is covered by 'U.S. Exports Regulation Program (USERP)'. / Physical security for space leased at a client location in sole support of that particular client, as validated and documented by Global Real Estate.

Note to applicability: In case baseline physical security requirements for owned or leased locations cannot be met, exceptions must be documented including secondary controls, approved by the Geographic Director of Security and reviewed every 12 months.

Overall Audit Objectives

The objective of this audit program is to determine, in conjunction with the IBM Security Requirements Manual (SECMAN), that:

1. There is a management process that assures definition of the requirements applicable and appropriate for the organization and the environment (e.g., S&S vs. M&D).
2. There is a management system to implement the defined scope and covers the following:
 - a. Procedures have been implemented to ensure a secure business environment for IBM employees and other persons working in IBM facilities.
 - b. Emergency plans covering anticipated emergencies and catastrophes have been established, and the plans adequately address the protection of people and assets. (This does not include Disaster Recovery or Business Recovery Services.)
 - c. Procedures have been implemented to timely report and analyze security incidents, bring them to closure, and mitigate reoccurrence.
 - d. There are effective management actions to protect proprietary information and assets from unauthorized disclosure, modification, or misappropriation.
3. There is a process to provide management with a validation that the security implementations are operating effectively.

SITE SECURITY

AUDIT PROGRAM #48-20-00

PLANNING: Audit Program Risk Alignment

Site Security

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Physical Security - Exterior and Interior Security	High	Physical Security - Exterior and Interior Security	All
Physical Security - Master Keys and Controlled Access System	Medium	Physical Security - Master Keys and CAS	All
Data Privacy and IT Security	Medium	Data Privacy and IT Security	All
Risk Analysis	Medium	Risk Analysis	All
Emergency Planning and Crisis Management	Medium	Emergency Planning	All
Incident Management and Investigations	Low	Incident Management	All
Contract Management	Low	Contract Management	All

SITE SECURITY AUDIT PROGRAM #48-20-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

The last audits show a high amount of data especially for security accesses.

Please contact the process owner for hints and tips and be very specific, which data you really need. This is relevant for the IDR, but also for the field work.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Concern
Measurements List of all key measurements reported by management (including MSA - management self-assessment)	Review a sample of key measurements to ensure: - The creation methodology being utilized is appropriate. - The information within each report is accurate. - A root cause analysis is being performed for all key issues and the appropriate action plans are in place. - Management is properly reviewing and approving the reports.	Inaccurate or incomplete measurements could hinder management's ability to make key decisions. This could lead to sub optimal resource allocations, budget overages, or inappropriate activity from being detected.
Contract Management Universe of all contracts, scope of works (SOW) signed and managed during the audit period.	Select a sample of contracts to verify whether: - Contract included all required terms and conditions. - Deliverables were clearly defined, and measurements were specified in the contract. - There was a process to track and monitor contract deliverables. - Firm price was included in the contract, or there was clear documentation for how services and prices would be determined.	If all binding terms and conditions, as well as a clear definition of the scope of work, are not clearly stated in the contract, IBM is subject to prolonged disputes with suppliers. If contracts are not properly controlled, they may result in higher cost to IBM.

SITE SECURITY AUDIT PROGRAM #48-20-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Disbursements A list of all disbursements/payments made during the audit period should be provided for analysis. Universe of all credit notes referring related to disbursements or payments made during the audit period.	Review a sample of disbursements/PO payments to validate: • If an independent verification of goods or services was performed. • Whether price and quantity matched commitment included in scope of work. • In cases PO payments exceeded PO commitments, verify that activity is tracked and reconciled. • Whether there were any duplicate payments made, and what controls/root cause analysis was done in such situations. Select a sample of credits to ensure: • Credit notes are issued promptly by the supplier. • Credit amounts were properly recorded, or credit amount was deducted from subsequent payments to the supplier.	Inaccurate or incomplete documentation clearing stating terms and conditions and pricing could lead to incorrect payments to suppliers. Insufficient evidence supporting confirmation of goods/services were received and validating all necessary approvals were obtained could lead to unauthorized payments.
Application Management List of all applications, databases and IT tools	Review the application listing to determine if there are any unique systems outside of BAU support systems. Review should also include application access, including analysis of access and controls where third parties are involved in the AM process.	Continued Business Need check not performed, and employees may move to other roles leading to SoD conflicts. Process or control weaknesses should be considered in the context of application controls, in particular reconciliations between systems.

SITE SECURITY

AUDIT PROGRAM #48-20-00

PLANNING: Reference Material

Please refer to the following websites:

IBM Corporate Security Website

<http://w3-03.ibm.com/security/secweb.nsf/ContentDocsByCtryTitle/Corporate~Corporate+Security+home?Open&Country=Corporate>

IBM Security Manual (SECMAN)

<https://ibm.ent.box.com/file/578730023352?s=zi3k5b4wcnw1hmcpl16ntitvd4g374s>

Information Technology Security Standard (ITSS)

<https://pages.github.ibm.com/ciso-psg/main/standards/itss.html>

Industrial Control Systems (ITSS ICS)

<https://pages.github.ibm.com/implementation-guides/Industrial-Control-Systems/>
<https://pages.github.ibm.com/implementation-guides/Industrial-Control-Systems/>

Global Privacy Assessment (GPA)

<https://w3.ibm.com/ibm/privacy/gpa>

Mixed Address Database (MAD)

<https://w3-03.ibm.com/services/security/ipaddress/home.action.wss>

SITE SECURITY

AUDIT PROGRAM #48-20-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
An individual with responsibilities which would permit the initiation and concealment of irregular activity, without detection, could result in loss to IBM. Specifically, by providing or using unauthorized physical access or IDs.	Adequate review of Controlled Access System (CAS) operator authorization or permissions should minimize the risk of fraud.	Determine whether the processes and technology in support of physical access are operating effectively. Review the latest version of the security manual related CAS operator authorizations and permissions (section PS05.6). Validate that user IDs are assigned to all CAS operating personnel in compliance with ITCS104 and authorization reviews are performed every six months.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contract Management

Objective:

If site security services have been contracted to a vendor, are there controls to ensure a well-defined business relationship exists between IBM and the vendor?

Risk/Exposure:

A well-defined business relationship is required to ensure that IBM's dealings with vendors are conducted fairly. Dealings in any other fashion could result in collusive activity or negatively impact vendor relations.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contract Management

Primary Test: Contract Management (CM001.P)

Objective:

To determine whether our business relationship with the security vendor is well defined through effective contract terms, conditions, and operating procedures.

Approach:

1. Review the contracts covering the security vendor(s) used during the audit period. While the original contract should be on file with General Procurement (GP), copies should be available at the site.
2. Determine if the vendor has subcontracted any responsibility. Determine if the contract contains a clause allowing subcontracting activity. Verify that IBM management monitors subcontracted activity as defined in the contract.
3. Review risk acceptances, if applicable, to ensure they are properly prepared, approved, and revalidated as required (at least annually).
4. Review charges flowing to the security minor through the general ledger. Identify exceptions, for example: months with higher payments, payments charged to security that are not from the primary security vendor, late payments, payments to the security vendor that are under different purchase orders than the main agreement. From these exceptions, test the following:
 - a. Review a sample of purchase orders, and verify that releases contain essential elements including prices, rates, commitment levels, and authorized names; and these elements match the blanket purchase order.
 - b. Review a sample of invoices and verify that invoiced services were received and consistent with contract terms.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Contract Management

Secondary Test: Contract Management-Information Access (CM002.S)

Objective:

To determine whether controls limit vendor access to required information.

Approach:

1. Determine whether the vendor has on-line access to IBM systems, and verify that access is appropriately authorized, restricted to essential items and personnel, and reviewed.
2. Review the contract and/or location requirements to ensure predefined training subject matter has been identified by the location and communicated to the supplier.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Risk Analysis

Objective:

To determine whether management has incorporated appropriate analysis into the plans and execution of security programs.

Risk/Exposure:

Without sufficient analysis, security risks could remain unidentified and thus unaddressed, compromising safety and security in IBM locations.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Risk Analysis

Primary Test: Risk Analysis (RA001.P)

Objective:

To determine whether management has analyzed and documented potential security risks for the IBM location(s).

Approach:

Review the latest version of the security manual related to risk analysis (section RA00). Based on the guidelines, determine if a location risk analysis has been performed, reviewed, and approved within the last twelve months (or earlier if the location risk changed) and documented using the IBM Notes WW Risk Analysis Database. Also verify if a corresponding location/site emergency plan exists within the WW Emergency Planning database. Verify that a country security risk analysis has been completed within the last twelve months and that it was evaluated and approved by the Geographic Director of Security.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Physical Security - Exterior and Interior Security

Objective:

Is access to the IBM facility adequately controlled?

Risk/Exposure:

Insufficient access controls could expose IBMs perimeter, facilities, and parking facilities so that the facility is insecure for employees and visitors and their property.

Lack of adequate controls over specifically defined space could result in a loss of intellectual and physical assets or create an insecure work environment for personnel.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Physical Security - Exterior and Interior Security

Primary Test: Exterior Access Controls (PS001.P)

Objective:

To determine whether sufficient controls are in place at the selected IBM facility to deter and detect unauthorized access to:

- External Utility Areas
- Parking Facilities
- Building Entrances

Approach:

Review the latest version of the security manual related to exterior security (section PS01).

1. Verify that Facilities management has posted signs indicating property boundaries and entry restrictions.
2. Validate that critical utilities have been identified, documented, and revalidated within the last twelve months. Determine if the required controls are implemented.
3. Verify that the defined perimeter lighting requirements have been met.
4. Verify that access from the parking structure into IBM internal space is secure and controlled.
5. Verify that there are physical deterrents (such as barriers or landscape techniques) which impede vehicular access to IBM controlled/managed lobbies or other glassed areas of buildings, where there is a concentration of people. These requirements are baseline for new construction after June 1, 2003, and optional prior to that date.
6. Verify that other less obvious points of entry accessible from the ground level into IBM owned, managed, or controlled space, such as operable windows which can be opened more than ten (10) inches (25 cm), grills, grates, manhole covers, utility tunnels, sky lights, and roof vents are secured.
7. Verify that there is a clear line of sight maintained around building exterior wall(s).
8. If identified as an enhanced security control, verify that perimeter fences are installed and meeting the specified requirements. Verify if those installations were appropriately reviewed (by the Corporate Security Systems Strategy and Technology Team) and approved by the Geographic Director of Security. (Must follow perimeter fence specifications for any new or replacement fence after December 17, 2013.)
9. All proposals for design, renovation or construction of an IBM Security control center must be reviewed and approved by the Corporate Security Systems Strategy team (section PS06).

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Physical Security - Exterior and Interior Security

Primary Test: Interior Access Controls (PS002.P)

Objective:

To determine whether appropriate access controls are in place within the audited facilities.

Approach:

Review the latest version of the security manual related to building perimeters and interior security (section PS02). Test for specific controls related to the various types of designated space.

- Perimeter doors
- Windows and exterior glass walls
- IBM interior space
- Alternative work location(s)
- Third Party Data Center Perimeter Security
- Staffed lobbies
- IBM managed/controlled loading docks
- IBM specially designated area(s)
- IBM shared space
- Tenant space
- Credit union, automated teller facilities, or banks

1. Verify that all perimeter doors (entry, egress, emergency exits, and docks) are constructed of heavy-duty material. Determine if the door jambs, latches, hinges, locks, etc. are protected from bypass exposure. Ensure there are access controls (such as CAS or other approved locking device), alarms, and CCTV covering all perimeter doors. Where remote access doors exist, ensure there are controls to identify individuals prior to allowing access into the building interior. Also, where elevators provide access directly into IBM interior space, ensure there is a means to control access, such as CAS, vestibules, and so forth.

(Note: Perimeter door alarm and video (CCTV) requirements are optional for facilities defined as Basic [Reference: IBM Security Manual - PS02.1 - Table 2 - Summary of Perimeter Door Physical Security Protection], unless the risk of crime or terrorism is rated High or Extreme. Video (CCTV) requirement is also optional for facilities that were leased or owned prior to December 31, 2012.)

2. Where the overall risk of terrorism is determined to be high or extreme risk as defined in the WW Risk Analysis database, validate that a location assessment was conducted; reviewed and documented by the Geographic Director of Security. Also verify if Anti-Shatter Security Film (ASF) has been installed adjacent to vulnerable areas and if those assessments were submitted to the Corporate Security Systems Strategy and Technology team prior to implementation and communicated to the Senior Location Executive and Global Real Estate.
3. Determine if IBM interior space, such as hallways, office areas, and other such spaces occupied and/or managed by IBM, is isolated from general use areas (such as lobbies and public restrooms) with slab-to-slab wall construction techniques, wire screen and ceiling tile clips or electronic alarms. Additional controls may be applicable, e.g., CCTV and/or alarms. Where access to IBM interior space by tenants is allowed, verify access is authorized by IBM management and access controls are defined in a license, lease, or other type of legal document.
4. Determine if alternative locations exist. If so, verify if a pre-occupancy security and risk assessment was conducted and whether the alternative location is protected in accordance with baseline security requirements.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Physical Security - Exterior and Interior Security

Primary Test: Interior Access Controls (PS002.P)

(Continued)

5. Determine if third party data center locations exist where third party provided security controls are implemented. If so, verify if third party security controls at the outer perimeter of the IBM leased space have been assessed by IBM Security and meet the baseline security requirements.
6. Where there are staffed lobbies located in general use or publicly accessible areas, verify that there are written emergency response processes in place that include a means to train lobby, security, or other designated personnel on those processes every 12 months and that there are panic/duress controls to inconspicuously notify a security control center or other continuously staffed workstation in the event of an emergency.
7. When IBM shares space with non-IBM functions, verify that controls are implemented to limit access from shared space into IBM interior space, such as through the use of CAS, perimeter walls, alarms, cipher locks, or other IBM Security approved locking mechanism.
8. In locations where third party/vended banking operations exist (to include automated teller machines), validate that there is a process in place for third party monitoring for response to robberies and burglaries with alarm responses reported to IBM Security. Where a security control center exists, ensure there are parallel alarms or procedural controls implemented and no obligation for IBM to respond to incidents or alarm activations or system maintenance. If third party/vended banking operations do not provide third party monitoring, validate there is a Hold Harmless Agreement in place with IBM included as an additional insured on the third party/vended banking operation insurance policy.
9. Validate that IBM owned, and managed security alarm and video (CCTV) devices and infrastructure are connected to an IBM Security Control Center or other continuously staffed workstation. Verify that functionality and operability of those devices and infrastructure was validated through testing at the required minimum testing frequencies and that the testing, to include identification and resolution of deficiencies through corrective action, was appropriately documented.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Physical Security - Exterior and Interior Security

Primary Test: Mail Services Security (PS003.P)

Objective:

To determine whether appropriate access controls are in place for the mail services area.

Approach:

Review the latest version of the security manual related to mail handling and mail room security (section PS03).

1. Verify that registered & certified mail and/or IBM confidential mail are not delivered to unattended or unsecured mail delivery locations and is held and secured behind a locked door or within locked furniture.
2. Validate that access to the dedicated or multi-purpose mail room is restricted to authorized individuals only and a controlled access system or cipher lock is used.
3. Verify that doors are designed to protect against forced entry and prevent unauthorized access.
4. Verify that undelivered registered and certified and IBM confidential mail is secured behind a separate locked door or locked furniture within the mail room. In a dedicated mail room, this is not required if intrusion detection is installed that covers the entire mail room area.
5. Verify that there are printed instructions for the identification and handling of suspicious packages posted in the dedicated or multi-purpose mail rooms.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Physical Security - Exterior and Interior Security

Primary Test: Search Policy (PS007.P)

Note: This test must be performed for manufacturing locations.

Objective:

Verify that the processes and technology in support of search activities, as authorized within IBM Business Conduct Guidelines, are operating effectively.

Approach:

Review the latest version of the security manual related to IBM's search policy (section PS07).

1. Validate that search of personal effects, made without the employee's knowledge, are approved by management.
2. Validate that the policy for electronic searches (such as metal and tagging detectors, x-ray machines, and handheld wands) has the documented approval of the senior location manager/senior location executive or the country general manager and that local Legal Counsel, IBM Security and Human Resources have been consulted. Determine if local laws have been followed.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Physical Security - Master Keys and CAS

Objective:

Is access to the IBM facility adequately controlled?

Risk/Exposure:

If the process for badge controls is ineffective the physical access control program may be ineffective.

Lack of adequate controls over locks and keys could result in an insecure business environment for employee property, loss of IBM proprietary information, and loss of IBM physical assets.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Physical Security - Master Keys and CAS

Primary Test: Lock and Key Controls (PS004.P)

Objective:

To determine whether lock and key program controls are adequate to deter and detect misuse. These requirements are only applicable to facilities where IBM has exclusive control of all keys providing access to IBM space.

Approach:

Review the latest version of the security manual related to lock and key controls (section PS04).

1. Validate that the issuance of all keys that provide access to IBM space, to include master keys, sub-master keys and core keys as defined in the security manual, is adequately controlled.
2. Validate that the following additional controls for master, sub-master, and core keys exist:
 - a. Daily and/or shift accountability is maintained. Note: An Electronic Key Management System as defined in PS04 is considered an effective control for meeting this requirement.
 - b. Keys are restricted and controlled.
 - c. If more than six of either master, sub-master, or core keys exist, IBM Security staff documents approval every twelve months.
 - d. Process to control access to master, sub-master or building access keys kept outside of security to allow landlords, facility operations and fire/emergency response personnel access.
 - e. If firefighter access boxes, Knox lock boxes, or electronic key management systems as defined in PS04 are used, verify that these boxes are alarmed to a security control center or constantly staffed workstation.
3. Determine if supplies and equipment such as key blanks, duplicate keys, unissued keys, key codes, pinning combinations are secured and access limited.
4. If key control processes are maintained by an IBM supplier, verify they are bonded, insured, and/or licensed.
5. For locations where IBM does not manage the key control process, ensure IBM Security has assessed landlord key controls and if deficiencies were identified, confirm that secondary controls (such as door forced alarms) were implemented.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Physical Security - Master Keys and CAS

Primary Test: Access Controls and Badge Designs (PS005.P)

Objective:

To determine whether the processes and technology in support of physical access are operating effectively.

Approach:

Review the latest version of the security manual related to access controls and badge designs (section PS05).

1. Determine if CAS (permanent and/or temporary) or single-use non-CAS badges are issued per requirements, for example:
 - a. Documentation of management authorization/approval (or management notification if an online request system for general employee use is implemented) prior to the issuance of CAS identification badges to all employees and non-regular employees.
 - b. Proof of identity was obtained prior to a badge being issued to non-IBM personnel.
 - c. Single-use non-CAS badges (yellow) for non-regular employees are authorized by an IBM manager, IBM coordinator, or authorized pre-designated contract company supervisor.
 - d. Visitor identity (those requiring escort and issued red badges) must be validated by a government ID or the person authorizing the visit.
 - e. Badges are in compliance with the IBM Security Manual design requirements (for example, IBM logo, digital cover photo, recognizable color scheme, and so forth) and any exceptions (such as joint ventures/subsidiaries as defined in the IBM Security Manual and/or tenant badges, where issued) have required reviews/approvals documented.
 - f. In the event a permanent badge is reported as "forgotten", a process to issue a temporary CAS badge for a period no greater than necessary.
2. Validate that all badges have an expiration date in the CAS system: ten years for employees and two years from current calendar date for non-regular employees.
3. Validate that all CAS hardware, including badge stock, badge equipment, and other associated badge making components are secured.
4. Verify that an effective process is in place to remove employee and non-regular employee access in a timely manner:
 - a. Secure area manager reports are reviewed by secure area managers or designees every 90-95 days.
 - b. Non-regular employee reports are distributed to authorizers of non-regular employee CAS badges every 90-95 days and a process exists to demonstrate access authorization has been reviewed.
 - c. Non-regular employee badges not used within 90 days are deactivated.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Physical Security - Master Keys and CAS

Primary Test: Access Controls and Badge Designs (PS005.P)

(Continued)

- d. Every 30 days, IBM Security must match the CAS database with the HR database. (Note: If separations are being performed by the Enterprise Directory (ED) Trigger automated process, the 30-day match is not required.)
 - e. Temporary CAS badges not returned on the due date are deactivated.
 - f. Badges reported as lost are deactivated within 24 hours of Security notification.
 - g. Badges are deactivated when a business need for access is no longer required. Deactivation must occur within 24 hours of Security notification if the process is automated and within three business days of Security notification if the process is manual.
 - h. Deactivated badge profiles are kept in the CAS database for six months.
5. Verify if a process exists as per the requirements in section PS05.2 for visitors to IBM locations, such as guests, retirees, and clients.
6. Verify that active, functional temporary CAS badges with access to IBM's perimeter are inventoried daily.
- a. Temporary CAS badges secured in a firefighter's access or Knox lock box that is alarmed to a security control center or other continuously staffed workstation are exempt.
 - b. Inactive temporary CAS badges do not require a daily inventory. If they are activated, they must be inventoried daily until they are deactivated again.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Physical Security - Master Keys and CAS

Secondary Test: Badge Designs and Technology (PS006.S)

Objective:

Verify that the processes and technology in support of physical access are operating effectively.

Approach:

Review the latest version of the security manual related to access controls and badge designs (section PS05).

1. Validate that CAS readers which are alarmed are tested according to the requirements in section PS02.14.
2. The following testing should be conducted at the Controlled Access System (CAS) Hub Center, rather than the individual sites:
 - a. Verify that a process exists to effectively ensure critical CAS data is backed up and available in the event of a disaster.
3. Validate that user IDs are assigned to all CAS operating personnel in compliance with the IT Security Standard and authorization reviews are performed and documented every six months.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Emergency Planning

Objective:

Have emergency plans been established and tested, and do they adequately address anticipated emergencies and catastrophes?

Risk/Exposure:

Lack of adequate emergency plans could result in the risk of loss of life, material damage, and loss of profit.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Emergency Planning

Primary Test: Emergency Planning (EP001.P)

Objective:

To determine whether emergency plans have been established by senior location management which adequately address anticipated emergencies and catastrophes.

Approach:

Review the latest version of the security manual related to emergency planning (section EP01).

1. For each IBM location where employees are assigned, verify that the senior location management has a location emergency plan in place that contains procedures for immediate response to emergencies including prompt reporting through the Geographic Director of Security to Corporate Security. Note: Campus type locations with multiple contiguous addresses are permitted to have a single emergency plan that covers the campus.
2. Validate that the emergency plan addresses various types of emergencies (that is, natural or man-made disasters; threats or acts of violence against people or property; political/civil disturbances or demonstrations, and catastrophic events in close proximity to the site) and that all other requirements outlined in section EP01.2 are met.
3. Validate that IBM Security has reviewed the emergency plan within the last six months and updated the plan as needed.
4. Validate that the location emergency plan is filed in the WW Emergency Planning database, a corresponding location risk analysis is filed in the WW Risk Analysis database and that the senior location executive certifies by November 15th each year that the plan is current, and the required elements of the plan have been completed.
5. Verify that a Crisis Management Team (CMT) has been designated and the requirements for the CMT are met in accordance with EP01.2.
6. Verify that an annual CMT exercise was completed prior to November 15th of the calendar year.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Incident Management

Objective:

Are processes effective in reporting, investigating, and closing security related incidents?

Risk/Exposure:

Investigations which are not conducted as required may expose IBM to potential liability.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Incident Management

Primary Test: Reporting Incidents (IM001.P)

Objective:

To determine whether there is an implemented process for the reporting of incidents to security.

Approach:

Review the latest version of the security manual related to reporting significant incidents and responses (section IM02).

1. Verify that a process exists to report all significant incidents (for example, threats of serious nature, robberies, assaults, bomb related incidents, sabotage, explosions, serious information loss, demonstrations, major environmental incidents, and data loss) immediately to Corporate Security.
2. Validate that the location or country has implemented the Security Incident Management System (SIMS) for reporting and classifying types of incidents and that relevant incidents are reported.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Incident Management

Secondary Test: Investigations (IM002.S)

Objective:

To determine whether incidents are investigated, reported, and closed appropriately.

Approach:

Review the latest version of the security manual related to investigations (section IM01).

1. Validate that incidents have been reported to the Corporate Security department and Legal, as appropriate, and that knowledge of the investigation is limited to persons with a need to know.
2. Validate that investigations referred to, conducted by, or employing Federal authorities or government officials, or those that use third-party consultants or suppliers were referred to Corporate Security Worldwide Investigations team.
3. Validate that the use of covert monitoring for investigative purposes (for example, cameras and audio recorders) is approved as required in section IM01.1.
4. Verify that any actions involving the covert purchase or sale of suspected stolen IBM property have the approvals as required in section IM01.1.
5. Verify that security data has been released in accordance with section IM01.2.
6. Verify that notifications to law enforcement agencies were made, as defined in section IM01.3, and that IBM Security notified IBM Legal Counsel and the Geography Director of Security.
7. Verify that, prior to implementation, special security measures were approved by the Geographic Director of Security, and the Vice President of Corporate Security was notified.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Data Privacy and IT Security

Objective:

To validate if Information Technology (IT) devices comply with Information Technology Security Standard (ITSS) and ITSS Industrial Control Systems (ICS).

Risk/Exposure:

Failure to control IT devices could result in unauthorized and undetected access to devices, denial of service, legal liabilities, and could also expose IBM confidential information. In addition, inadequate controls over processing, transferring, and retaining personal information (PI) and sensitive personal information (SPI) could result in misuse of this data and damage IBM's reputation.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Data Privacy and IT Security

Primary Test: Data Privacy and IT Security (DP001.P)

Objective:

To validate if Information Technology (IT) devices comply with ITSS (Information Technology Security Standard) and ITSS ICS (Industrial Control Systems).

Approach:

Data Privacy

1. Validate if Data Processing Agreement (DPA) was signed with vendors. Also, validate if references to pictures or video recordings were included in the exhibit where the type of processed PI/SPI data was assessed through consultation of security closed circuit television (CCTV) records and verification of visitors' identity.
2. Global Privacy Assessment (GPA)
 - a. Validate evidence of the approved text of the privacy notices were in line with the GPA.
 - b. Validate evidence of an alternate process to ensure that notification was provided to visitors with vision disabilities.
 - c. Validate if CCTV systems were properly set up to ensure timely disposal of records.
 - d. Validate process in place to ensure timely disposal of PI/SPI stored for controlled access system (CAS) purposes.
 - e. Validate if a GPA was documented for all applicable security applications? (e.g., CAS, Badge Request applications, Visitor registration, etc.)

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Data Privacy and IT Security

Primary Test: Data Privacy and IT Security (DP001.P)

(Continued)

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

IT Security - Site Security Owned or Managed IP Connected Devices

1. Review adherence to IT Corporate Standards, including ITSS and the ICS technical specifications.
2. Verify the completeness and accuracy of Site Security owned or managed Internet Protocol (IP) connected devices (inventory), including cameras, video management systems (VMS), network supported access control micro controllers (such as PXNplus), and the associated IP addresses, physical location, and description. The inventory should include firmware versions for the devices.
 - a. Verify there are no duplicates, typo's, incorrect entries.
 - b. Verify all servers were registered in MAD (Mixed Address Database). Refer to (ITSS 3.1).
 - c. Verify if all security IP devices with network connectivity were secured behind an approved firewall.
 - d. Verify whether there was a process to keep the firmware of all CCTV and VMS and other devices up to date.
 - e. Verify if the network connectivity for all security IP devices were identified (e.g., IBM Network, Private Network, VPN, Public ISP, etc.) and have non-compliant connections (i.e., Public ISP) been terminated where they exist. Verify if a device was on an Internet IP address, instead of an Intranet IP address.
 - f. Verify if devices with high or medium severity vulnerabilities were properly addressed.
 - g. Verify if there were nonfunctioning devices.
 - h. Verify if the inventory was complete.
3. Verify that access to the connected devices was restricted and controlled.
 - a. Validate whether the credentials (userid / password) of CCTV and VMS were changed in line with the IT security requirements.
 - b. Validate if corporate security system devices were monitored to detect logical tampering.
 - c. Validate if there was a possibility to login through an insecure clear text (non-encrypted) protocol, e.g.:
 - i. Hyper Text Transfer Protocol (HTTP) (port 80)
 - ii. File Transfer Protocol (FTP) (port 21)
 - iii. Telnet (port 23)
4. Validate the Business Information Security Officer approval as appropriate as described in ITSS ICS.
5. In case a risk evaluation (RE) was created:
 - a. Verify if identified risk/s were mitigated at planned date.
 - b. Verify if mitigation action/s addressed the root cause/s as expected.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Employee Transportation Services

Objective:

To validate that the safety practices and programs for transportation of employees or contractors protect the safety of individuals and comply with local country and IBM Transport policy. requirements as laid out by Employee Relationship and Labor Relationship (ER & LR) and Corporate Health and Safety (CH&S).

Risk/Exposure:

The failure to abide by guidelines and policies as mandated by ER & LR and CH&S in accordance with local country and IBM guidelines and lack of a process to monitor and address any issues could significantly impact employee safety, could lead to employee dissatisfaction, non-compliance to legislative requirements, and could impact IBM's image.

SITE SECURITY

AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Employee Transportation Services

Primary Test: Employee Transportation Services (TS001.P)

Objective:

To validate that the safety practices and programs for transportation of employees or contractors protect the safety of individuals and comply with local country and IBM Transport policy requirements as laid out by Employee Relationship and Labor Relationship (ER & LR) and Corporate Health & Safety (CH&S).

Approach:

Scope

To be limited to only Employee Transportation Services as provided by the India transport organisation.

Notes:

1. This testing may not be applicable to all auditable units as the responsibility of transport services varies across organizations. As of 2017, this test under the Site Security Program is only applicable for IBM India.
2. The Women Declaration tool is managed by ER&LR and hosted on Commute@IBM (Employee Transport) servers.
3. Other transportation services managed directly by the business units like project cabs or availing third-party cab services like Uber or OLA to commute to and from office, or other cabs usage by employees to shuttle between airport, office, third-party client location are not included in the scope of this testing.

Approach

Review a sample of transportation contracts and related safety measures to verify if there is a regular oversight to ensure compliance with safety and legislative requirements.

Especially validate if:

1. Local laws on transportation security are adhered to as defined by ER & LR and CH&S in accordance with local country and IBM Transport policy.
2. Security and transportation contracts are enforced and monitored for compliance (e.g., supplier deliverables met) in line with the respective city/site SOW.

NOTE: Please note the responsibility of the process and policy (ER&LR) and the Commute@IBM (Employee Transport) tool as per above note.

3. Required vehicle and driver inductions were performed (e.g., police verification received, or third-party agency verified / criminal background check performed on transport and escort security personnel).
4. All IBM BU projects/employees who have requested for transportation services from the IBM India Employee Transport team (e.g., women employees working in night shift) are completely covered with IBM approved vendors in line with IBM Transport policy as governed by ER & LR and CH&S in accordance with local country and IBM Transport policy.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 9. Education

Objective:

To determine whether employees are appropriately trained and whether location management has received education materials from Security.

Risk/Exposure:

Without sufficient and frequent education, security risks could remain unidentified and thus unaddressed by all employees or mishandled by associated personnel, compromising safety and security in IBM locations.

SITE SECURITY AUDIT PROGRAM #48-20-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 9. Education

Primary Test: Education (ED001.P)

Objective:

To determine whether employees are appropriately trained and whether location management has received education materials from Security.

Approach:

Review the latest version of the security manual related to education and awareness (section ED01).

1. Verify that IBM Security provides functional advice, support, and distribution of education and training materials to line management to educate employees on the security processes. Verify if IBM Security ensures that general security information is distributed to all employees at least every twelve months.
2. Verify that IBM Security has confirmed there is a process to distribute education and awareness materials to assist line management in educating and/or training employees relative to their security responsibilities every twelve months. Among others, this should include training for appropriate personnel on handling suspicious packages and threatening calls as well as facility evacuation training. Determine whether line management provided the training and appropriately documented and maintained the education and training activities.